

Pet Territory Wars — Security Architecture v1.0

Kapsam: Go backend, Flutter mobile, PostgreSQL, Walk Worker

Öncelik: Hesap güvenliği, konum gizliliği, GPS manipülasyonu ve API kötüye kullanımı

MVP yaklaşımı: Çok katmanlı ama yönetilebilir güvenlik

1. Amaç

Bu doküman Pet Territory Wars MVP'sinin güvenlik sınırlarını tanımlar.

Korunması gereken ana varlıklar:

Oyuncu hesapları
Access ve refresh token'lar
Raw GPS rotaları
Hex ownership
Dominance değerleri
Skorlar
RuleSet'ler
Walk processing sistemi
Database erişimi

En kritik güvenlik prensibi:

Mobil cihazdan gelen hiçbir oyun sonucu güvenilir kabul edilmez.

Flutter yalnızca GPS ve cihaz sinyali gönderir. Walk geçerliliği, capture, attack, dominance ve skor kararı backend tarafından verilir.

2. Tehdit Modeli

MVP'de öncelikli tehditler:

Başka oyuncunun kaynağına erişme
Çalınmış veya tekrar kullanılan token
GPS spoofing
Değiştirilmiş mobil uygulama
Aynı Walk'ı birden fazla işleme
API rate limit abuse
Aşırı GPS payload gönderme
Leaderboard veya territory scraping
SQL injection
Hassas konum verisinin loglara sızması

Database credential sızıntısı
Worker job'larının iki kez uygulanması

OWASP API Security Top 10; nesne seviyesinde yetki kontrolü, authentication, property-level authorization ve sınırsız kaynak tüketimini API'ler için temel riskler arasında sayar. Bu nedenle her ID tabanlı erişimde ownership kontrolü ve bütün yoğun endpoint'lerde kaynak sınırı uygulanacaktır.

3. Authentication

MVP giriş yöntemleri:

Google Sign-In
Sign in with Apple

Mobil uygulama sağlayıcıdan identity token alır.

Backend:

1. Token'ın imzasını ve issuer bilgisini doğrular.
2. Audience değerini kontrol eder.
3. Token süresini kontrol eder.
4. Sağlayıcı kimliğini auth_subject ile eşleştirir.
5. Kendi access ve refresh token'ını üretir.

Mobil sağlayıcı token'ı doğrudan bütün API çağrılarında kullanılmayacaktır.

4. Access Token

Önerilen access token:

Format: İmzalı JWT
Süre: 15 dakika
Taşıma: Authorization Bearer header

JWT içinde minimum bilgiler bulunur:

```
{  
  "sub": "player-id",  
  "sid": "session-id",  
  "iat": 0,  
  "exp": 0,  
  "iss": "pet-territory-api",
```

```
"aud": "pet-territory-mobile"  
}
```

JWT içine şu bilgiler eklenmez:

```
Email  
Display name  
GPS verisi  
Pet detayları  
Yetki dışında hassas profil verileri
```

Access token database'de düz metin olarak saklanmaz.

5. Refresh Token

Refresh token:

```
Random ve tahmin edilemez olmalı  
Secure storage içinde tutulmalı  
Database'de yalnızca hash'i saklanmalı  
Her kullanımda rotate edilmeli
```

Önerilen süre:

30 gün

Rotation akışı:

```
Refresh token kullanılır  
↓  
Eski token iptal edilir  
↓  
Yeni access token oluşturulur  
↓  
Yeni refresh token oluşturulur
```

Eski refresh token tekrar kullanılırsa ilgili session ailesi şüpheli kabul edilip kapatılabilir.

Logout sırasında session revoke edilir.

6. Mobil Token Güvenliği

Token'lar:

```
iOS → Keychain  
Android → Keystore destekli secure storage
```

içinde tutulur.

Yasak:

```
SharedPreferences  
Normal SQLite tablo  
Plain-text dosya  
Log  
Crash report  
Analytics event
```

7. Authorization

Authentication ile authorization ayrıdır.

Her kaynak erişiminde oyuncu sahipliği kontrol edilir.

Örnek:

```
GET /walks/{walkId}
```

için:

```
walk.player_id == authenticated_player_id
```

olmalıdır.

UUID kullanılması yetki kontrolü yerine geçmez. OWASP, nesne kimliği tahmin edilemese bile her ID tabanlı endpoint'te object-level authorization yapılmasını gerekli görür.

MVP authorization kuralları:

```
Oyuncu yalnızca kendi Walk'ını okuyabilir.  
Oyuncu yalnızca kendi pet'ini değiştirebilir.
```

Oyuncu yalnızca kendi Walk'ına point gönderebilir.
Player ID request body'den kabul edilmez.
Leaderboard ve territory yalnızca güvenli public alanlar döndürür.
Internal job ve admin endpoint'leri public API'ye açılmaz.

8. API Güvenliği

Bütün production trafiği TLS üzerinden çalışır.

HTTP istekleri HTTPS'e yönlendirilir.

API katmanında:

Body size limit
JSON depth limit
Array item limiti
String length limiti
Coordinate aralığı kontrolü
Timestamp format kontrolü
UUID format kontrolü
Rate limiting
Request timeout

uygulanır.

SQL sorguları yalnızca parametrelili çalışır.

Dynamic ORDER BY veya kolon seçimi gerekirse whitelist kullanılır.

9. Rate Limiting

Rate limiting yalnızca IP bazlı olmayacaktır.

Mümkün olduğunda:

IP
Player ID
Session ID
Endpoint grubu

birlikte değerlendirilir.

Öncelikli limitler:

Login ve token refresh
Walk oluşturma
GPS batch upload
Walk finish
Walk polling
Territory viewport
Leaderboard

429 Too Many Requests cevabında:

Retry-After: 15

döndürülür.

Rate limit değerleri config üzerinden değiştirilebilir.

10. Idempotency ve Replay Koruması

Aşağıdaki isteklerde Idempotency-Key zorunludur:

Walk oluşturma
GPS batch upload
Walk finish

Koruma katmanları:

Walk ID
Player ID
Idempotency key
Request body hash
Batch sequence
Point sequence
Input hash
Walk status
Unique database constraint

Aynı idempotency key farklı body ile gelirse:

409 IDEMPOTENCY_KEY_REUSED

döner.

Aynı Walk ikinci kez skor veya territory değişikliği üretmez.

11. GPS Spoofing Koruması

GPS spoofing tek bir sinyalle çözülemez.

MVP’de risk tabanlı doğrulama uygulanır.

Kontrol edilen sinyaller:

```
Mock location flag
İmkânsız hız
Ani konum sıçraması
Timestamp sırasızlığı
GPS accuracy
Tekrarlanan yapay rota paterni
Aynı koordinatların olağan dışı tekrarı
Şehir sınırı
Walk süresi ve mesafesi
Cihaz bütünlük sinyali
```

Sonuç:

```
VALID
PARTIALLY_VALID
INVALID
RISK_REVIEW
```

şeklinde değerlendirilebilir.

Mobilin gönderdiği:

```
speedMps
distance
isMockLocation
```

alanları yalnızca sinyaldir; backend mesafeyi ve hızı yeniden hesaplar.

12. Uygulama Bütünlüğü

Android tarafında Play Integrity API, isteklerin gerçek uygulamadan, Google Play üzerinden edinilmiş kurulumdan ve güvenilir cihaz ortamından gelip gelmediğini değerlendirmeye yardımcı olur.

iOS tarafında App Attest, backend’in bağlanan istemcinin geçerli uygulama örneği olduğuna dair kriptografik doğrulama yapmasına imkân verir.

MVP kararı:

Play Integrity ve App Attest ilk public pilot öncesinde eklenir.
Faz 0 simulator geliştirmesini bloke etmez.

Integrity sonucu tek başına ban nedeni olmayacaktır.

Kullanım:

Normal → Walk işlenir
Riskli → Daha sıkı doğrulama
Yüksek risk → Walk reddedilebilir veya incelemeye alınabilir
Servis geçici kullanılamıyor → Kullanıcı otomatik cezalandırılmaz

13. Konum Gizliliği

Raw GPS en hassas veridir.

Kurallar:

Raw GPS API loglarına yazılmaz.
Raw GPS analytics'e gönderilmez.
Başka oyuncuya canlı konum gösterilmez.
Tam adres gösterilmez.
Harita yalnızca H3 territory state gösterir.
Raw GPS PostgreSQL'de sınırlı süre tutulur.
Local raw GPS senkronizasyon sonrası temizlenir.

Başlangıç retention:

Backend raw GPS: 60 gün
Mobil raw GPS: İşlem tamamlandıktan sonra en fazla 24 saat

Kesin retention mağaza politikaları, KVKK/GDPR değerlendirmesi ve kullanım şartlarıyla uyumlu hale getirilmelidir.

14. Veri Minimizasyonu

Database ve API yalnızca ihtiyaç duyulan veriyi tutar.

Yasak kopyalar:


```
Walk tablosunda display name
Territory tablosunda owner adı
Her log kaydında GPS koordinatı
JWT içinde email
Her event payload'ında tüm domain nesnesi
```

Outbox payload'ı yalnızca event'i işlemek için gerekli alanları içerir.

15. Database Güvenliği

Database public internete açılmaz.

Yalnızca private Docker ağı veya hosting private network üzerinden erişilir.

Roller:

```
migration_user
application_user
readonly_user
backup_user
```

Application user:

```
Schema değiştiremez
Database oluşturamaz
Superuser değildir
Yalnızca gerekli tablo işlemlerini yapabilir
```

Backup'lar şifrelenir.

Production verisi development ortamına doğrudan kopyalanmaz.

16. Secret Yönetimi

Secret örnekleri:

```
Database password
JWT signing key
OAuth secret
Apple private key
Third-party API key
```

Kurallar:

```
Git repository'ye girmez.  
Docker image içine gömülmez.  
Loglanmaz.  
Production'da hosting secret manager kullanılır.  
Rotate edilebilir olmalıdır.
```

Local `.env` yalnızca geliştirme içindir.

17. Worker Güvenliği

Walk Worker public HTTP endpoint açmaz.

Job claim:

```
FOR UPDATE SKIP LOCKED
```

ile yapılır.

Koruma:

```
walk_id unique job  
job attempt limit  
Walk status kontrolü  
ExpectedVersion  
score change unique constraint  
outbox event uniqueness
```

Worker crash olduğunda locked job belirli süre sonra yeniden alınabilir.

Sınırsız retry yoktur.

18. Log Güvenliği

Loglanmayacaklar:

```
Latitude  
Longitude  
Route point listesi  
Access token  
Refresh token
```

```
Authorization header
OAuth identity token
Database password
Integrity token'ın tamamı
```

Loglarda kullanılabilecek güvenli korelasyon alanları:

```
trace_id
request_id
player_id
walk_id
job_id
error_code
```

Kullanıcıya raw database veya stack trace hatası dönülmez.

19. Güvenlik Event'leri

İzlenecek güvenlik event'leri:

```
Repeated refresh token
Invalid integrity assertion
Excessive batch upload
Impossible speed
Repeated duplicate Walk
Authorization failure
Rate limit breach
Suspicious input size
Multiple failed authentication
```

Bu event'ler audit veya structured log olarak tutulabilir.

Her sinyal otomatik ban üretmez.

20. Dependency Güvenliği

CI'da:

```
govulncheck
Dependency update bot
Flutter dependency audit
Container image vulnerability scan
```

çalıştırılır.

Bağımlılıklar minimum tutulur.

Terk edilmiş location, auth veya crypto package'ları kullanılmaz.

21. Incident Temelleri

Şüpheli güvenlik olayı durumunda:

1. Etkilenen session'ları revoke et.
2. İlgili RuleSet veya feature'ı devre dışı bırak.
3. Log ve audit kayıtlarını koru.
4. Secret sızıntısı varsa rotate et.
5. Etkilenen Walk'ları yeniden hesaplama veya iptal için işaretle.
6. Kullanıcı etkisini belirle.

Raw GPS gereksiz yere incident raporlarına kopyalanmaz.

22. MVP Güvenlik Kontrol Listesi

TLS aktif
Object-level authorization aktif
Access token kısa ömürlü
Refresh token rotation aktif
Secure storage aktif
Idempotency constraint'leri aktif
Rate limiting aktif
Payload limitleri aktif
Parameterized SQL zorunlu
Raw GPS loglanmıyor
Database public değil
Secret repository'de değil
Worker retry sınırlı
RuleSet immutable
Backup şifreli
Play Integrity / App Attest pilot öncesi aktif

23. Nihai Karar

MVP güvenlik modeli:

Backend-authoritative game state
Kısa ömürlü access token
Rotating refresh token
Resource ownership kontrolü
Idempotent Walk işlemleri
Çok sinyalli GPS doğrulama
Uygulama bütünlüğü kontrolü
Konum verisi minimizasyonu
Rate ve payload limitleri
Private PostgreSQL
Least-privilege erişim

üzerine kurulacaktır.

Temel güvenlik prensibi:

İstemci veri sağlar; güven ve oyun kararı backend tarafından üretilir.